Chapter 1. 개요

목차

1.1 등장 인물

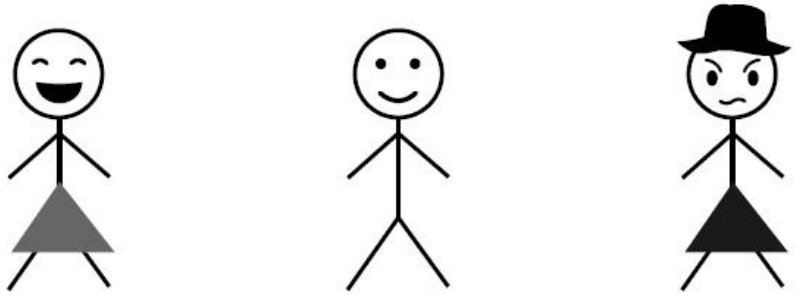
1.2 앨리스 온라인 은행

1.3 이 책에 대하여

1.4 사람 문제

1.1 등장인물

➢ 이 책의 주요 등장인물



(a) 앨리스 (b) 밥 (c) 트루디

그림 1-1 이 책의 주요 등장 인물

- 정상적인 사용자 : 앨리스, 밥
- 침입자 : 트루디(intruder에서 따옴)
- 기타 인물
  - 착한 역할 : 찰리, 데이브
  - 악한 역할 : 이브(eavesdropper에서 따옴)

1.2 앨리스 온라인 은행(AOB) – 정보보안 3요소(CIA)

➢ Alice가 온라인 은행 사업자이고 Bob이 고객이라 할 때, 정보보안을 위해 관심을 가져야할 사항

- 기밀성(Confidentiality)
  - 허가받지 않은 자는 정보의 내용을 알지 못하도록 보장하는 것
  - 예) 은행 고객들은 거래 내역 등 에서 취급하는 정보의 기밀성이 지켜지기를 원함

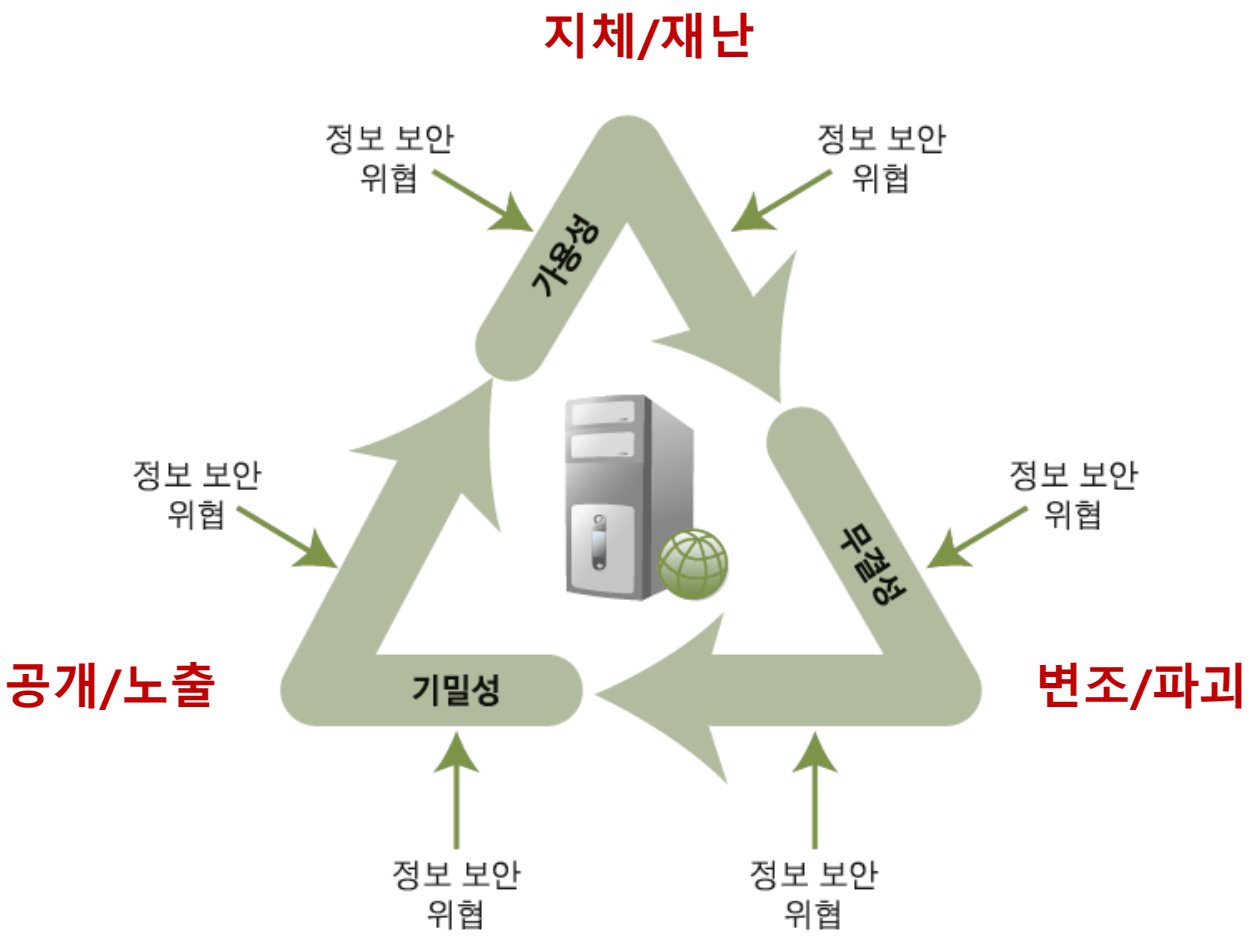
- 무결성(Integrity)
  - 허가받지 않은 자는 정보에 내용을 기록(변경)할 수 없게 하여 그 정보가 원본임을 보장하는 것
  - 예) 공격자가 자신의 은행 계좌 잔고를 증액시키거나 다른 사람의 계좌 잔액을 변경하지 못하도록 해야 함

- 가용성(Availability)
  - 권한이 있는 사람이 필요한 때에 정보에 접근할 수 있도록 보장하는 것
  - 예) 은행 고객들은 원하는 시점에 자신의 계좌에 접근하는 등 서비스를 사용할 수 있어야 함

[참고] 정보보안 3요소(CIA)

정보보호

정보 자산을 공개/노출, 변경/파괴, 지체/재난 등의 위협으로부터 보호하여 정보의 **기밀성, 무결성, 가용성**을 확보하는 것



[정보보안 3요소]

1.2 앨리스 온라인 은행 – CIA를 넘어서

➢ 기밀성, 무결성, 가용성 외에도 고려되어야 하는 정보보안 요소

- **인증(Authentication)**
  - Bob이 자신의 계좌에 접근하기 위해 로그인했을 때, **은행 서버는 그가 공격자가 아니고 진짜 'Bob' 이라는 것을 확신**할 수 있게 하는 절차
  - 예) ID/PW, 생체 인증, 인증서 등을 이용한 사용자 인증 절차 필요

- **인가(Authorization)**
  - 인증된 사용자 Bob의 활동을 제한하도록 설정하는 것(특정 리소스나 기능을 사용할 수 있는 권한을 허락)
  - 예) 은행 서버가 Bob을 인증한 후, Bob이 자신의 계좌가 아닌 다른 사람의 계좌에 접근하거나 계좌 잔액을 임의로 조작하는 등의 행동을 하지 못하도록 사용자의 권한을 제한할 필요가 있음

※ 인증과 인가는 모두 자원 접근과 관계되는 문제이므로 Part 2 **접근제어(access control)**에서 세부적인 내용 다룰 예정

1.3 이 책에 대하여

- 이 책에서는 정보보안 관련 주제를 크게 4부로 나누어 기술함
  - 암호(cryptography) : 기밀성과 무결성 보장을 위해 사용하는 정보보호의 기본 도구
    - 고전 암호체계
    - 대칭키 암호 방식과 공개키 암호 방식
    - 해시 함수
    - 스테가노그래피(steganography)
    - 추가 내용 : 키 분배, 전자서명
  - 접근제어(Access control) : 인증 및 인가
    - 인증 : 패스워드, 생체인증, 스마트 카드 등 인증 방식
    - 인가
      - 접근제어 목록(ACL)과 권한 목록(capabilities)
      - 다단계 보안(multilevel security)
      - 은닉 채널(covert channels)
      - 추론 제어(inference control)

1.3 이 책에 대하여

- **네트워크 보안** : 네트워크에서 발생할 수 있는 보안 공격에 대응하기 위한 프로토콜
  - 방화벽(firewall)
  - 재전송 공격(replay attack) 대응 방안
  - 보안 셸(SSH)
  - 보안 소켓 계층(SSL)
  - IPSec
  - 커버로스(kerberos)
  - WEP와 GSM

- **소프트웨어**
  - 소프트웨어의 보안 결함
  - 악성 코드

1.4 사람 문제

➢ 사용자의 부주의

- 암호체계, 프로토콜, 접근제어, 소프트웨어가 완벽하게 설계되었더라도 **사용자가 부주의하면 보안에 취약점**이 생김
- 가능한 사용자가 일으킬 수 있는 문제 요소를 없애는 것이 중요

메일 참조 실수, 고의적인 유출, 범죄 집단의 내부자 모집...내부자로 인해 벌어지는 보안사고들

2023년 경찰청 국가수사본부의 발표에 따르면 산업스파이 91%가 내부자

※기사 출처 : 보안뉴스(https://www.boannews.com/media/view.asp?idx=115440)

[참고] 정보보호 대책

정보보호를 위한 조치

물리적 조치
- 보안이 필요한 곳에 인가 받지 않은 자가 출입하는 것을 통제
  예) 중요 시설 보호, 출입 통제, 도청 방지, 중요 자료의 백업 및 재난 복구 등

기술적 조치
- 정보 시스템, 서버, 네트워크 등에 대한 위험 요소와 취약점을 분석하고 필요한 보안 기술 적용
  예) 시스템 접근 통제, 데이터 암호화 등

관리적 조치
- 정보에 대한 보호 및 관리를 위해 보안정책을 수립
  예) 인원 관리, 정보시스템 사용에 대한 절차 관리, 사고 대책 관리 등

참고 – 정보보안기사 기출문제 예

➢ 다음 정보보호의 목표 중에서 분실 및 도난 대비하는 것은?(정보보안기사 필기 2024. 06)

① 기밀성
② 무결성
③ 가용성
④ 부인봉쇄

참고 – 정보보안기사 기출문제 예

➢ 다음 중 올바른 것을 고르시오.(정보보안기사 필기 2024. 03)

a. 기밀성 : 정보가 허가되지 않은 사용자(조직)에 노출되지 않는 것을 보장하는 원칙이다.
b. 무결성 : 정보가 권한이 없는 사용자의 악의적 또는 비 악의적인 접근에 의해 변경되는 것을 보장하는 원칙이다.
c. 가용성 : 인가된 사용자(조직)가 정보시스템의 데이터 또는 자원을 필요로 할때 부당한 지체없이 원하는 객체또는 자원을 접근하고 사용할 수 있는 것을 보장하는 보안 원칙이다.
d. 부인봉쇄 : 송신자가 수신자에게 보낸 정보를 자신이 보내지 않았다고 부인하는 것을 차단한다.

① a, b
② a, b, c
③ c, d
④ a, b, c, d